Field Hours

CSCE 703 Cybersecurity Risk

Original notes for this site. Same topics as the catalog course. Not a reprint of another university's lectures, and not academic credit.

Lecture 1 · 90 minutes

Four treatments, one choice

You respond to a risk with 1 of 4 treatments: avoid, accept, mitigate, or transfer. The mechanism is a written choice tied to a scenario, not a mood. Avoid means you do not run the service. Accept means a named person signs the residual. Mitigate means a control changes the likelihood or the impact. Transfer means a contract moves a stated loss, for example the first 50000 dollars of a defined event, and it does not move the incident itself.

You do not stack the words as if they were one action. A firewall is a mitigation. An insurance clause that pays 50000 dollars is a transfer of money, while you still mitigate or accept what remains. If you shut the service off, you avoided that scenario, and the insurance is idle for it. This course, cross-listed as CYBR 603, asks you to name the treatment for each scenario you keep. A diagram with no treatment name is unfinished.

Pick one treatment and write it.

Avoid: do not run it

Accept: a person signs

Mitigate: a control changes the score

Transfer: a contract moves dollars

Insurance is not avoidance

1. The scenario is a defined outage. A contract pays the first 50000 dollars of that outage. That sentence is transfer.

2. You still run the service, so you did not avoid it. A firewall you also deploy is a separate mitigation on a different part of the score.

3. Whatever remains after the 50000 dollars needs accept or mitigate, named on its own. CYBR 603 wants one treatment per scenario you keep.

Problem 1. A contract pays the first 50000 dollars of a defined event, and you keep running the service. Which treatment is the contract, and which treatment did you not choose?

Answer. The contract is transfer of 50000 dollars. You did not choose avoid, because the service still runs. Transfer does not move the incident itself, so residual still needs accept or mitigate.

Problem 2. Your diagram shows a firewall and no treatment word. What is missing for CYBR 603?

Answer. The treatment name. A firewall is a mitigation only once you write mitigate and tie it to a scenario. Avoid, accept, mitigate, and transfer are 4 choices, and you pick 1 per scenario.

Lecture 2 · 90 minutes

Three levels, not one adjective

Categorization is a coarse impact label you assign before you shop for controls. The mechanism is a table with 3 levels: low, moderate, and high, applied to confidentiality, integrity, and availability separately. A public brochure site can be low for confidentiality and high for availability if an outage of 1 hour stops sales. You do not copy the brochure label onto the payroll store beside it. Two systems on one network can carry two different triples.

You write the level from a stated harm, not from a feeling that the system is important. If a confidentiality breach exposes 200 employee records, you point at a rule you set in advance, such as 100 or more records means high. 200 meets that bar, so confidentiality is high. Availability stays whatever your outage bar says. Mixing the two into one warm adjective hides which harm you meant. The triple is 3 decisions.

The same network can hold two triples.

Brochure site

Confidentiality can be low

One hour outage is high

Do not copy this triple

Payroll store

200 records meets high

Bar was 100 records

Availability is separate

Two hundred records

1. Your written bar says 100 or more exposed employee records means high confidentiality. The scenario exposes 200.

2. 200 is at least 100, so confidentiality is high. You do not also flip availability unless the outage bar says so.

3. The brochure site on the same network keeps its own triple. An outage of 1 hour can be high availability there and irrelevant to payroll confidentiality.

Problem 1. The bar is 100 or more records for high confidentiality. A breach exposes 200 records. What level do you assign, and by how many records does it clear the bar?

Answer. High. 200 minus 100 is 100, so it clears the bar by 100 records. Availability is a separate decision. You do not copy this label onto a different system.

Problem 2. The brochure site is low confidentiality and high availability because a 1-hour outage stops sales. May payroll inherit that pair?

Answer. No. Two systems can share a network and still need two triples. Payroll confidentiality follows

the record bar, such as 200 against 100. The brochure outage does not set it.

Lecture 3 · 90 minutes

The score is a product

You score a scenario as likelihood times impact, both integers from 1 to 5. The product is the mechanism that lets you compare unlike stories. Likelihood 4 and impact 5 give a score of 20. An unconfirmed rumor does not get a 4. You only score a scenario you can describe with an asset, a cause, and an effect. Those are 3 clauses. A score without the clauses is a number you should not sort on.

After a control, you rescore. If the control cuts likelihood from 4 to 1 and impact stays 5, the score falls from 20 to 5. The 5 is residual risk, and it is what accept or transfer must cover. You do not leave the old 20 on the chart once the control is in place and tested. A mitigation you have not tested does not earn the new likelihood.

Rescore only after the control is tested.

Before the test

Likelihood 4, impact 5

Product is 20

Untested work stays here

After a tested control

Likelihood 1, impact 5

Product is 5

Accept or transfer the 5

From 20 down to 5

1. The scenario has an asset, a cause, and an effect. Likelihood 4 times impact 5 is 20.

2. The control is in place and the test supports likelihood 1. Impact stays 5, so the residual product is 5.

3. You replace 20 with 5 on the chart. Accept or transfer has to cover 5, not the old 20, and not a rumor you never described.

Problem 1. Likelihood is 4 and impact is 5. After a tested control, likelihood is 1 and impact is still 5. What were the two scores?

Answer. 20 before, and 5 after. 4 times 5 is 20, and 1 times 5 is 5. The residual 5 is what accept or transfer must cover. An untested control does not earn the 1.

Problem 2. You wrote the number 20 and you cannot name the asset, the cause, or the effect. How many of the 3 clauses are present?

Answer. 0. You should not sort on that 20. A score is likelihood times impact only after the 3 clauses exist, and an unconfirmed rumor does not receive a likelihood of 4.

Lecture 4 · 90 minutes

Six names in order

You select a mitigation by tracing a scenario to a control. The mechanism is that trace. You use 6 step names and you do not merge them: categorize, select, implement, assess, authorize, and monitor. Select comes after the category. A high confidentiality system does not inherit the control set of a low brochure site. Implement is step 3 of the 6, and you record the configuration you actually deployed, not the one you planned.

The Risk Management Framework is the order you just named, and you apply it to 1 system rather than to a slogan. Implement is not authorize. A control that is installed and not assessed is still at step 3. You might have 9 controls selected and only 4 implemented. You report 4, not 9. Padding the count with planned work hides the residual you still carry at the old score.

Do not authorize a control that is only selected.

1. Categorize the system

2. Select from that category

3. Implement and record it

4. Leave assess for later

Nine selected, four installed

1. You categorized 1 system, then selected 9 controls that match that category. Selection is not implementation.

2. Four of the 9 are actually deployed, and you have the configuration for those 4. You report 4.

3. The other 5 stay planned. They do not lower last lecture's score of 20. Authorize has not started, because assess has not started.

Problem 1. You selected 9 controls and implemented 4. What count do you report as implemented, and how many are still only planned?

Answer. Report 4 implemented. 9 minus 4 is 5 still planned. Planned controls do not change the residual score. Implement is step 3 of 6, not authorize.

Problem 2. A low brochure site already has a control set. Confidentiality on the payroll store is high. May you skip categorize and reuse the brochure set?

Answer. No. Categorize comes before select. A high confidentiality system does not inherit a low site's controls. The 6 names stay in order: categorize, select, implement, assess, authorize, monitor.

Lecture 5 · 90 minutes

Evidence, then a signature

Assessment checks the control you implemented, and the mechanism is evidence against a stated test. If the test says inactive accounts are disabled after 30 days, you sample the account table. Suppose 5 of 20 inactive accounts are still enabled. Then 15 pass and 5 fail, and you do not write that the control works. Authorize is a

person accepting the result, including those 5 failures, for a period you name, such as 180 days.

You distinguish an authorization from a passing grade. The official can authorize with failures present if they record the residual score, for example likelihood 2 times impact 5 equals 10. That 10 is what they accepted. You do not let an assessor both write the finding and sign the acceptance. A package with 0 findings and 0 tests is not a strong result. It is a package that skipped assessment, which means you are not at the authorize step.

A signature sits on a sample, not on a hope.

State the 30-day test -> Sample the accounts -> Record passes and fails -> A different person signs

Five failures out of twenty

1. The test is disablement after 30 days. You sample 20 inactive accounts and find 5 still enabled.

2. Fifteen pass, because 20 minus 5 is 15. You do not write that the control works.

3. A different person may accept residual likelihood 2 times impact 5, which is 10, for 180 days. The assessor does not sign that line.

Problem 1. Of 20 inactive accounts, 5 are still enabled after the 30-day test. How many passed, and may you say the control works?

Answer. 15 passed, because 20 minus 5 is 15. You may not say the control works. Authorize can still accept the 5 failures only with a recorded residual, for a named period such as 180 days.

Problem 2. Likelihood 2 times impact 5 is the residual an official is willing to sign. What is the product, and may the assessor sign it?

Answer. The product is 10. The assessor does not sign it. Writing the finding and accepting it are different roles. A package with 0 tests is not at the authorize step.

Lecture 6 · 90 minutes

The authorization expires in practice

Monitoring is the step that keeps an authorization from becoming a souvenir. The mechanism is a repeated measurement on a schedule. You recheck the same account test every 30 days. If the next sample shows 8 failures out of 20 instead of 5, the control got worse, and the old acceptance does not cover the new count. You reopen the score. Audit is the version of that habit: an auditor samples, and you show the record rather than the intention.

You prepare for audit by tying each claim to an artifact. A claim that you disable inactive accounts needs the 30-day rule and a sample result. If the auditor pulls 10 of 40 controls, you can answer those 10 only if the artifacts exist before the visit. Building them during the meeting is not monitoring. The Cybersecurity Framework's 5 functions, identify, protect, detect, respond, and recover, are the language you use to group the artifacts.

Five function names for the audit folder.

Identify the system

Protect with the control

Detect by the sample

Respond when the count rises

Recover under a tested plan

Failures moved from 5 to 8

1. Last month, 5 of 20 inactive accounts failed the 30-day test, and someone accepted that result.

2. This month the same test shows 8 of 20. The old acceptance does not cover 8. You reopen the score.

3. The artifact is the sample, filed before any audit visit. If an auditor asks about 10 of 40 controls, only the ones with artifacts are answerable.

Problem 1. The accepted sample had 5 failures out of 20. The next 30-day sample has 8 failures out of 20. By how many failures did the control get worse?

Answer. 3 failures. 8 minus 5 is 3. The old acceptance does not cover the new count, so you reopen the score. Show the record, not the intention.

Problem 2. An auditor pulls 10 of 40 controls. How many controls were not pulled, and when must the artifacts exist?

Answer. 30 controls were not pulled, because 40 minus 10 is 30. Artifacts for the 10 must exist before the visit. The 5 Cybersecurity Framework functions are only the grouping language for those artifacts.

Lecture 7 · 90 minutes

One server you can actually name

You apply the whole path to 1 system you actually know, which is the mechanism that makes the framework yours. Pick a system with a boundary you can draw, such as a lab server used by 8 people. List 3 scenarios. For each, write the treatment, the score, and the control. If one scenario is likelihood 3 and impact 4, the score is 12. You do not import a generic risk register of 50 rows you cannot explain.

You walk that server through authorize and monitor, not only through a spreadsheet. Suppose the chosen control is account disablement at 30 days, and your sample finds 1 failure among 8 accounts. The residual is not zero. You ask a named person to accept it or to fund a fix, and you date the decision. Transfer does not fit this scenario unless a contract states a dollar amount. Avoid would mean turning the server off. You pick one.

Three scenarios on one server.

1. Draw the server boundary

2. Score three scenarios

3. Test the chosen control

4. Date the signature

One failure among eight accounts

1. The lab server has 8 people. One scenario is likelihood 3 and impact 4, so the product is 12, with a treatment and a control beside it.

2. The 30-day sample finds 1 failure among the 8 accounts. You do not call the residual zero.

3. A named person accepts that failure or funds a fix, with a date. You do not call it transfer unless a dollar amount is in a contract, and you do not call it avoid unless the server goes off.

Problem 1. Likelihood is 3 and impact is 4. What is the score, and how many scenarios does the closing system need in total?

Answer. The score is 12, because 3 times 4 is 12. The system needs 3 scenarios, each with a treatment, a score, and a control. A borrowed register of 50 rows does not count.

Problem 2. The server has 8 accounts and 1 of them fails the 30-day test. How many passed, and why is the residual not zero?

Answer. 7 passed, because 8 minus 1 is 7. The residual is not zero because 1 account is still enabled. A named person must accept it or fund a fix, with a date. Avoid would mean turning the server off.

Lecture 8 · 90 minutes

What you can now accept or refuse

You can now carry one system from a category to a monitored authorization. You can assign 3 impact levels, multiply likelihood 4 by impact 5 to get 20, and rescore to 5 when likelihood falls to 1. You can say which of the 4 treatments you chose, and you can refuse a transfer that names no dollar amount. Assessment evidence, such as 5 failures out of 20, is part of the decision.

The text for the hours is the NIST Risk Management Framework and the Cybersecurity Framework, read slowly and applied to the 1 system you know. These 8 lectures are the skeleton: 4 treatments, 3 levels, a product score, 6 ordered steps, and 5 functions for the audit folder. Your closing page lists 3 scenarios with scores and treatments. If a score is not a product you can recompute, this course is not finished.

The page that closes the course.

Name one real system -> Write three scored scenarios -> Attach the sample -> Recompute every product

Twenty, then five

1. Likelihood 4 times impact 5 is 20. After a tested control, likelihood 1 times impact 5 is 5. You can show both products.

2. The same page names the treatment. Transfer without a dollar amount is refused. Avoid, accept, mitigate, and transfer stay distinct.

3. The reading is the NIST Risk Management Framework and the Cybersecurity Framework, on 1 system. Three scenarios with recomputable scores close the course.

Problem 1. Before the control, likelihood is 4 and impact is 5. After the tested control, likelihood is 1 and impact is 5. What are the two products?

Answer. 20 and 5. 4 times 5 is 20, and 1 times 5 is 5. If you cannot recompute the product, this course is not finished. The 5 is the residual a person may accept.

Problem 2. A sample shows 5 failures out of 20, and the transfer column names no dollars. How many accounts passed, and is transfer available?

Answer. 15 passed, because 20 minus 5 is 15. Transfer is not available until a contract states a dollar amount. The 5 failures stay in the evidence the signature has to face.